

CISSP Manager-Mindset Guide

DOMAIN 1 | SECURITY AND RISK MANAGEMENT

Plain-English concepts • Manager decisions • Exam traps

PURPOSE A decision-oriented study guide for recognizing the best CISSP answer—not merely a technically possible answer.

Aligned to the ISC2 CISSP Certification Exam Outline effective April 15, 2024
Domain weight: 16%

How to Use This Guide

Read each topic for understanding, then use the manager-mindset line to frame decisions and the exam traps to eliminate attractive distractors. The CISSP exam commonly presents several actions that could be reasonable; the task is to select the action that best fits the role, authority, sequence, and business context in the question.

DEFAULT DECISION LENS Protect people first. Understand the business need and risk. Follow law and policy. Act within authority. Prefer a durable, risk-based solution over an improvised technical reaction.

The Domain 1 Manager Mindset

- Security exists to support the organization's mission and objectives.
- Senior management owns organizational risk; security professionals identify, analyze, communicate, and treat risk under approved authority.
- Policies express management intent. Standards and procedures turn that intent into consistent action.
- Assess before selecting controls. Do not begin with a favorite product or technology.
- Use controls proportionate to asset value, business impact, legal obligations, threat likelihood, and cost.
- When the question asks what to do first, look for prerequisites: scope, authorization, classification, BIA, risk assessment, or evidence preservation.
- Compliance is a minimum obligation, not proof that risk is acceptable or security is effective.
- Document decisions, approvals, exceptions, accountability, and residual risk.
- People and life safety take precedence over equipment, data, and evidence.

Domain 1 Roadmap

Objective	Focus	Primary decision question
1.1	Professional ethics	What is the ethical and properly escalated action?
1.2	Security concepts	Which security property must be protected?
1.3	Governance	Who has authority and how does security support the business?
1.4	Legal, regulatory, compliance	Which obligation applies and who must interpret it?
1.5	Investigations	What standard, authority, and evidence process applies?
1.6	Policy hierarchy	Which document expresses or implements management intent?
1.7	Business continuity	Which business functions and dependencies must recover first?
1.8	Personnel security	How is human risk controlled through the employment lifecycle?
1.9	Risk management	Who owns the risk and which treatment is justified?
1.10	Threat modeling	How can threats be identified early and systematically?
1.11	Supply chain risk	How are third-party dependencies governed and monitored?
1.12	Awareness and training	How is behavior changed and effectiveness measured?

1.1 Professional Ethics

Ethics questions test professional judgment, protection of the public, honesty, competence, and proper escalation—not personal convenience or blind loyalty to an employer.

ISC2 Code of Ethics

Easy definition: A professional code that requires CISSPs to protect society, act honorably, provide diligent and competent service, and advance the profession.

When it matters: Conflicts of interest, unsafe or unlawful instructions, misrepresentation, disclosure decisions, professional competence, and reporting misconduct.

THINK LIKE A MANAGER Protect society and act lawfully first; then serve the organization honestly, competently, and through proper channels.

EXAM TRAPS

- Putting an employer's reputation ahead of public safety or law.
- Publicly disclosing sensitive information before using authorized reporting and escalation paths.
- Accepting work outside your competence without disclosure or qualified assistance.
- Assuming an instruction from management eliminates your ethical responsibility.

QUICK DISTINCTION The canons are ordered: protect society; act honorably; provide diligent service to principals; advance and protect the profession.

Organizational Ethics and Conflicts of Interest

Easy definition: Organizational ethics define expected conduct inside the enterprise; a conflict of interest exists when personal interests could improperly influence professional judgment.

When it matters: Vendor selection, gifts, outside employment, family relationships, audit independence, procurement, and handling confidential information.

THINK LIKE A MANAGER Disclose the conflict promptly and remove or appropriately limit your role; transparency protects the decision process.

EXAM TRAPS

- Trying to remain 'objective' without disclosing the conflict.
- Assuming no conflict exists because the organization also benefits.
- Selecting a vendor based on personal trust instead of documented requirements and due process.
- Confusing confidentiality with permission to conceal illegal or unethical activity.

QUICK DISTINCTION A potential or perceived conflict should still be disclosed; actual bias does not have to be proven first.

Ethics Decision Order

Ask	Manager-oriented response
Could people or society be harmed?	Prioritize safety, law, and the public good.

Ask	Manager-oriented response
Is the action legal and authorized?	Confirm applicable requirements and authority.
Does policy provide a reporting path?	Use documented escalation and reporting mechanisms.
Am I competent and independent?	Disclose limitations or conflicts; obtain qualified help.
Is disclosure necessary?	Use minimum necessary, authorized disclosure; preserve confidentiality.

1.2 Core Security Concepts

Confidentiality, Integrity, and Availability (CIA)

Easy definition: Confidentiality prevents unauthorized disclosure, integrity prevents unauthorized or improper change, and availability ensures timely, reliable access for authorized users.

When it matters: Classifying incidents, selecting controls, defining requirements, assessing impact, and resolving tradeoffs.

THINK LIKE A MANAGER Start with the business requirement and impact; balance the three properties rather than maximizing one blindly.

EXAM TRAPS

- Choosing encryption for every problem; it mainly supports confidentiality and can support integrity when used with authentication.
- Treating a service outage as an integrity problem instead of availability.
- Assuming backups alone provide availability; restoration capability and time matter.
- Ignoring safety and operational availability in OT or healthcare contexts.

QUICK DISTINCTION Disclosure = confidentiality. Unauthorized alteration = integrity. Loss of timely access = availability.

Authenticity and Nonrepudiation

Easy definition: Authenticity provides confidence that an identity, message, or object is genuine; nonrepudiation provides evidence that makes a completed action difficult to credibly deny.

When it matters: Digital signatures, transactions, approvals, software provenance, message origin, and auditability.

THINK LIKE A MANAGER Choose controls that establish identity and preserve trustworthy evidence of the action—not merely secrecy.

EXAM TRAPS

- Claiming encryption alone proves who sent a message.
- Confusing authentication at login with proof of a specific later transaction.
- Assuming a shared key provides strong nonrepudiation; either party may possess it.
- Forgetting that evidence depends on key protection, identity proofing, timestamps, and reliable records.

QUICK DISTINCTION Authenticity asks ‘Is it genuine?’ Nonrepudiation asks ‘Can the responsible party credibly deny the action?’

Security Properties at a Glance

Property	Question	Typical supporting controls
Confidentiality	Who may see it?	Encryption, access control, need-to-know
Integrity	Has it been changed improperly?	Hashes, signatures, change control, validation
Availability	Can authorized users access it when needed?	Resilience, capacity, redundancy, recovery

Property	Question	Typical supporting controls
Authenticity	Is the identity or object genuine?	Authentication, certificates, signatures
Nonrepudiation	Can the action be credibly denied?	Digital signatures, trusted logs, timestamps

1.3 Security Governance

Governance vs. Management

Easy definition: Governance sets direction, priorities, accountability, and risk expectations; management plans and executes activities to achieve that direction.

When it matters: Board oversight, executive accountability, security strategy, program design, reporting, and performance measurement.

THINK LIKE A MANAGER Ensure security decisions trace to business objectives and an accountable authority; technology implements governance—it does not replace it.

EXAM TRAPS

- Treating governance as day-to-day administration.
- Letting the security team unilaterally decide the organization's risk appetite.
- Selecting controls before business requirements and risk are understood.
- Assuming the CISO owns every security risk.

QUICK DISTINCTION Governance says what outcomes and boundaries matter; management determines how to achieve them.

Organizational Roles and Risk Accountability

Easy definition: Roles assign decision authority and responsibility: executives provide direction and resources, business or data owners make risk and classification decisions, custodians implement controls, and users follow requirements.

When it matters: Risk acceptance, data classification, control implementation, audit findings, exceptions, and accountability.

THINK LIKE A MANAGER Send decisions to the role with the business authority and information needed to own the consequence; security provides analysis and recommendations.

EXAM TRAPS

- Having an administrator accept business risk because they operate the system.
- Confusing responsibility for performing work with accountability for the outcome.
- Assuming the auditor should design or operate the controls being audited.
- Letting vendors define the organization's risk tolerance.

QUICK DISTINCTION The owner decides and is accountable; the custodian implements and operates; the user complies.

Due Care and Due Diligence

Easy definition: Due care means taking reasonable protective action; due diligence means investigating, validating, and continually monitoring that the action remains appropriate and effective.

When it matters: Negligence, governance, vendor oversight, control operation, risk assessment, and evidence that management acted responsibly.

THINK LIKE A MANAGER Approve reasonable safeguards, assign accountability, and require ongoing evidence that they work.

EXAM TRAPS

- Treating a purchased control as completion of management's obligation.
- Viewing due diligence as a one-time review.
- Equating perfect security with reasonable care.
- Confusing written policy with proof that policy is followed.

QUICK DISTINCTION Due care = do the reasonable thing. Due diligence = investigate and keep verifying.

Security Frameworks

Easy definition: Frameworks provide structured ways to govern, manage, design, assess, or report security; they differ in purpose and should be selected to meet organizational needs.

When it matters: Program design, maturity improvement, control selection, audits, regulatory alignment, and architecture.

THINK LIKE A MANAGER Choose and tailor a framework based on objectives, obligations, risk, industry, and maturity; do not implement it as an unexamined checklist.

EXAM TRAPS

- Assuming one framework automatically satisfies every law or contract.
- Confusing a risk or governance framework with a prescriptive technical standard.
- Applying every control without scoping or tailoring.
- Treating compliance with a framework as proof that residual risk is acceptable.

QUICK DISTINCTION NIST often structures risk and controls; ISO provides certifiable management-system standards; COBIT emphasizes governance; SABSA is business-driven architecture; PCI DSS is an industry security standard; FedRAMP standardizes U.S. federal cloud authorization.

Policy and Strategy Alignment

EXAM RULE Business goals and risk requirements come before security architecture, products, or configurations. In acquisitions and divestitures, first establish governance, ownership, scope, obligations, risk, and integration objectives.

1.4 Legal, Regulatory, Privacy, and Compliance

Sources of Security Obligations

Easy definition: Organizations face requirements from laws, regulations, contracts, licenses, industry standards, and internal policy; each has a different source and enforcement mechanism.

When it matters: Compliance scoping, control requirements, contracts, audits, data handling, breach response, and cross-border operations.

THINK LIKE A MANAGER Identify every applicable obligation, resolve conflicts with qualified legal counsel, and translate requirements into owned, testable controls.

EXAM TRAPS

- Assuming an industry standard is automatically a statute.
- Treating internal policy as optional because it is not law.
- Letting technical staff make final legal interpretations.
- Meeting one requirement while ignoring contractual or jurisdictional obligations.

QUICK DISTINCTION Law is enacted; regulation implements legal authority; contract binds parties; standards may be voluntary until adopted by law, contract, or policy.

Privacy Principles

Easy definition: Privacy governs the appropriate collection, use, disclosure, retention, and protection of personal information—not merely keeping information secret.

When it matters: PII processing, consent, purpose limitation, data minimization, individual rights, retention, third parties, and international transfers.

THINK LIKE A MANAGER Collect only what is justified, use it only for defined purposes, protect it proportionately, retain it only as required, and provide required transparency and rights.

EXAM TRAPS

- Equating privacy with confidentiality alone.
- Collecting extra data because it might be useful later.
- Assuming consent cures every privacy issue.
- Ignoring derived data, metadata, models, backups, and third-party copies.
- Applying the organization's home jurisdiction to all data regardless of subject or processing location.

QUICK DISTINCTION Security asks how information is protected; privacy also asks whether and why it should be collected, used, shared, and retained.

Transborder Data Flow and Jurisdiction

Easy definition: Cross-border processing can subject data and organizations to multiple jurisdictions, transfer restrictions, localization rules, contracts, and government-access requirements.

When it matters: Cloud services, multinational operations, remote support, global vendors, backups, analytics, and mergers.

THINK LIKE A MANAGER Map where data originates, travels, is processed, and is stored; involve privacy and legal experts before choosing transfer mechanisms or locations.

EXAM TRAPS

- Assuming encryption eliminates transfer restrictions.
- Looking only at server location and ignoring access, support, subprocessors, or backups.
- Assuming the strictest known law automatically resolves all conflicts.
- Moving data first and reviewing legal requirements later.

QUICK DISTINCTION Data location is necessary but insufficient; consider the data subject, controller, processor, access paths, and applicable jurisdictions.

Intellectual Property, Licensing, and Import/Export Controls

Easy definition: Intellectual-property and licensing rules govern authorized use of creations and software; import/export controls can restrict transfer of technologies, encryption, technical data, or services across borders.

When it matters: Software inventories, open-source use, source code, trade secrets, cloud deployment, international collaboration, and cryptographic products.

THINK LIKE A MANAGER Verify rights and restrictions before copying, modifying, deploying, sharing, or exporting protected material or controlled technology.

EXAM TRAPS

- Assuming internet availability means permission to use or redistribute.
- Treating all open-source licenses as identical.
- Ignoring license limits in virtualized or cloud environments.
- Assuming an electronic transfer is not an export.
- Trying to interpret complex export restrictions without legal or compliance expertise.

QUICK DISTINCTION Copyright protects expression; patent protects inventions; trademark protects source identifiers; trade secret protection depends on maintaining secrecy.

1.5 Investigation Types

Administrative, Civil, Criminal, Regulatory, and Contractual Investigations

Easy definition: Investigation types differ in authority, purpose, procedure, burden of proof, and consequences.

When it matters: Employee misconduct, lawsuits, suspected crimes, regulatory inquiries, audit failures, and industry-standard violations.

THINK LIKE A MANAGER Identify the investigation type and controlling authority before collecting evidence or interviewing people; coordinate with legal, HR, compliance, and law enforcement as appropriate.

EXAM TRAPS

- Using the same evidence standard and process for every investigation.
- Contacting law enforcement without following organizational escalation and legal guidance unless immediate safety or law requires it.
- Conducting intrusive monitoring without policy, notice, consent, or authority.
- Allowing an internal investigation to contaminate evidence needed for a criminal case.

QUICK DISTINCTION Criminal generally uses the highest burden ('beyond a reasonable doubt' in U.S. courts); civil commonly uses 'preponderance of the evidence'; administrative and regulatory matters follow their governing rules.

Evidence Reliability and Chain of Custody

Easy definition: Evidence must be relevant, reliable, authentic, and handled in a documented way that accounts for possession and protects integrity.

When it matters: Forensics, disciplinary actions, litigation, regulatory response, and any investigation in which evidence may be challenged.

THINK LIKE A MANAGER Preserve first when circumstances permit, minimize alteration, use trained personnel, document every transfer and action, and maintain repeatable procedures.

EXAM TRAPS

- Immediately examining the original device when a forensic image can be made.
- Confusing a hash with the entire chain of custody.
- Failing to document who collected, transferred, stored, and accessed evidence.
- Prioritizing evidence over imminent life safety.
- Assuming technically interesting data is legally admissible.

QUICK DISTINCTION Chain of custody shows who controlled the evidence; hashing helps demonstrate that the evidence did not change.

Investigation Comparison

Type	Typical purpose	CISSP cue
Administrative	Internal policy or employment matter	Coordinate with HR/legal; follow policy and authorized monitoring.
Civil	Resolve disputes and liability	Preserve discoverable evidence; counsel directs legal strategy.

Type	Typical purpose	CISSP cue
Criminal	Determine violation of criminal law	Strict evidence handling; coordinate with law enforcement and counsel.
Regulatory	Determine compliance with regulatory duties	Meet reporting, preservation, and cooperation obligations.
Industry/contract	Assess adherence to agreed standards	Follow contract, assessment rules, and remediation process.

1.6 Policy, Standards, Procedures, and Guidelines

The Documentation Hierarchy

Easy definition: Policy states management intent and mandatory direction; standards define mandatory requirements; procedures provide required step-by-step actions; guidelines offer recommended flexibility.

When it matters: Governance, control consistency, training, audits, enforcement, and operational execution.

THINK LIKE A MANAGER Begin with approved policy, translate it into measurable standards, create repeatable procedures, and use guidelines where judgment is appropriate.

EXAM TRAPS

- Choosing a procedure when the question asks for high-level management direction.
- Calling a mandatory requirement a guideline.
- Writing technical detail into policy that will quickly become obsolete.
- Assuming an unpublished or unenforced policy demonstrates due care.
- Changing a procedure without appropriate change control or ownership.

QUICK DISTINCTION Policy = why/what. Standard = mandatory rule. Procedure = exact steps. Guideline = recommended approach.

Document Hierarchy Comparison

Document	Nature	Example
Policy	High-level, mandatory management intent	Sensitive data must be protected according to classification.
Standard	Specific mandatory requirement	Restricted data must use approved encryption at rest.
Procedure	Required sequence of actions	Steps to provision, rotate, escrow, and revoke keys.
Guideline	Recommended, allows judgment	Suggested patterns for creating memorable passphrases.
Baseline	Minimum configuration or control set	Approved hardened configuration for Windows servers.

FIRST-ACTION TRAP If the problem is inconsistent behavior across the organization, the best first answer may be to establish or update policy and ownership—not to deploy a tool. If policy already exists, determine whether standards, procedures, training, enforcement, or monitoring are failing.

1.7 Business Continuity Requirements

Business Continuity vs. Disaster Recovery

Easy definition: Business continuity keeps essential business functions operating through disruption; disaster recovery restores technology and supporting capabilities after disruption.

When it matters: Resilience planning, crisis response, alternate processes, recovery strategies, dependency management, and testing.

THINK LIKE A MANAGER Let business requirements drive recovery priorities; technology recovery is one part of sustaining the mission.

EXAM TRAPS

- Starting with server recovery instead of critical business functions.
- Treating BC and DR as synonymous.
- Assuming every system requires the same recovery time.
- Ignoring people, facilities, communications, suppliers, utilities, and manual workarounds.
- Building a plan without exercising and maintaining it.

QUICK DISTINCTION BC protects continued business operation; DR restores technology and infrastructure that support it.

Business Impact Analysis (BIA)

Easy definition: A BIA identifies critical functions, impacts of disruption over time, dependencies, recovery priorities, and recovery requirements.

When it matters: Before selecting continuity or recovery strategies, negotiating recovery service levels, or investing in resilience.

THINK LIKE A MANAGER Ask business process owners to define impact and acceptable disruption; use the results to justify priorities and resources.

EXAM TRAPS

- Treating the BIA as a threat or vulnerability assessment.
- Letting IT assign business criticality alone.
- Selecting a hot site before recovery requirements are known.
- Considering only financial impact and ignoring safety, legal, operational, and reputational impact.
- Failing to identify upstream and downstream dependencies.

QUICK DISTINCTION BIA asks what happens if a function is unavailable; risk assessment also asks what threats and likelihoods could cause loss.

RTO, RPO, MTD, and WRT

Easy definition: RTO is the target time to restore a capability; RPO is the maximum tolerable data-loss window; MTD is the longest total disruption the business can tolerate; WRT is time needed after technology restoration to validate and resume business processing.

When it matters: Recovery design, backup frequency, alternate sites, resilience investment, service-level requirements, and testing.

THINK LIKE A MANAGER Derive time objectives from business impact, then choose solutions capable of meeting them at acceptable cost and risk.

EXAM TRAPS

- Confusing RPO with time to restore.
- Setting every RTO to zero without business justification.
- Allowing RTO plus WRT to exceed MTD.
- Assuming backup completion proves the RPO and RTO can be achieved.
- Ignoring data reconciliation and operational validation after technical restoration.

QUICK DISTINCTION RPO looks backward: how much data may be lost? RTO looks forward: how quickly must service return? MTD is the outer business limit.

Continuity Metrics

Metric	Plain-English question	Example
RPO	How far back can we lose data?	15 minutes of transactions
RTO	How soon must the capability be restored?	Service restored within 4 hours
WRT	How long to validate and resume work after restoration?	2 hours to reconcile and restart processing
MTD/MTPD	What is the longest total outage the business can survive?	8 hours maximum disruption

1.8 Personnel Security

Employment Lifecycle Controls

Easy definition: Personnel security applies controls before hiring, during employment and transfers, and at termination to reduce human and access risk.

When it matters: Screening, agreements, onboarding, training, access provisioning, role changes, disciplinary processes, and offboarding.

THINK LIKE A MANAGER Apply consistent, lawful, risk-based controls to the entire lifecycle; adjust access immediately when responsibilities change or employment ends.

EXAM TRAPS

- Performing screening without legal authority, consent, or relevance to the role.
- Provisioning access before approvals and training are complete.
- Adding new access during a transfer without removing obsolete access.
- Delaying high-risk termination access revocation.
- Focusing only on employees and ignoring contractors and vendors.

QUICK DISTINCTION Joiner = approved onboarding. Mover = revalidate and adjust access. Leaver = timely revoke, recover assets, preserve records, and remind of continuing obligations.

Separation of Duties, Job Rotation, and Mandatory Vacation

Easy definition: These controls reduce fraud and error by dividing sensitive tasks and periodically exposing work to independent performance or review.

When it matters: Financial transactions, privileged administration, change approval, code deployment, audit functions, and other high-risk processes.

THINK LIKE A MANAGER Design processes so no single person can authorize, execute, and conceal a sensitive action; ensure coverage and independent review.

EXAM TRAPS

- Confusing least privilege with separation of duties.
- Assuming two accounts used by the same person create separation.
- Using job rotation without logging or review.
- Treating mandatory vacation as a reward rather than a detective control.
- Allowing operational urgency to make permanent exceptions.

QUICK DISTINCTION Least privilege limits what one identity can do; separation of duties divides a process among different people or roles.

Third-Party Personnel Agreements

Easy definition: Contracts and agreements establish security, confidentiality, access, performance, notification, audit, return or destruction, and termination expectations for external personnel.

When it matters: Consultants, contractors, managed services, temporary workers, vendors, and partners.

THINK LIKE A MANAGER Define requirements and accountability before access or data sharing begins, then monitor performance and revoke access at the end of need.

EXAM TRAPS

- Relying on the vendor's standard terms without mapping organizational requirements.
- Granting broad access because a contractor is temporary.
- Assuming an NDA covers availability, incident notification, or control obligations.
- Failing to address subcontractors and fourth parties.
- Ending the contract without confirming data return, destruction, and access revocation.

QUICK DISTINCTION An NDA protects confidentiality; an SLA defines measurable service performance; the broader contract allocates duties, rights, liability, and remedies.

1.9 Risk Management

Threat, Vulnerability, Likelihood, Impact, and Risk

Easy definition: A threat can cause harm, a vulnerability is a weakness, likelihood estimates occurrence or exploitation, impact measures consequence, and risk reflects uncertainty about objectives—often expressed through likelihood and impact.

When it matters: Risk identification, analysis, prioritization, control selection, reporting, and treatment.

THINK LIKE A MANAGER Describe risk in business terms: a credible threat exploits a vulnerability and causes an impact to an objective or asset.

EXAM TRAPS

- Calling every vulnerability a risk without a threat, exposure, or business consequence.
- Using severity alone as the remediation priority.
- Ignoring existing controls when estimating current risk.
- Treating likelihood estimates as certainty.
- Reporting only technical scores to executives.

QUICK DISTINCTION Vulnerability = weakness. Threat = potential cause. Risk = uncertainty and potential business consequence created by their interaction.

Risk Appetite, Tolerance, Capacity, and Threshold

Easy definition: Risk appetite is the amount and type of risk the organization is willing to pursue or retain; tolerance defines acceptable variation around objectives; capacity is the maximum risk the organization can absorb; thresholds trigger action or escalation.

When it matters: Strategy, investment, exception decisions, escalation, KRIs, control objectives, and risk reporting.

THINK LIKE A MANAGER Senior leadership sets risk direction; translate it into measurable limits and escalation triggers for managers and operators.

EXAM TRAPS

- Letting security set enterprise risk appetite.
- Using appetite and tolerance as exact synonyms.
- Assuming willingness to accept risk can exceed legal obligations or actual financial capacity.
- Creating thresholds without an owner or response process.

QUICK DISTINCTION Appetite is broad willingness; tolerance is allowed variation; capacity is the hard limit; threshold is the point that triggers action.

Risk Responses: Avoid, Mitigate, Transfer, and Accept

Easy definition: Avoidance stops the risky activity; mitigation reduces likelihood or impact; transfer allocates some financial or operational consequence to another party; acceptance knowingly retains residual risk.

When it matters: Treatment plans, control selection, outsourcing, insurance, contracts, exceptions, and executive decisions.

THINK LIKE A MANAGER Recommend options with cost, benefit, residual risk, and obligations; the accountable risk owner approves acceptance.

EXAM TRAPS

- Assuming insurance removes the underlying risk or accountability.
- Calling outsourcing risk avoidance.
- Accepting risk informally because remediation is expensive.
- Spending more on controls than the justified reduction in risk.
- Ignoring new risks introduced by the treatment.

QUICK DISTINCTION Transfer shares consequences; it does not transfer ultimate accountability. Acceptance must be informed, authorized, documented, and reviewed.

Inherent, Residual, and Secondary Risk

Easy definition: Inherent risk exists before controls, residual risk remains after controls, and secondary risk is introduced by the chosen treatment.

When it matters: Control evaluation, exceptions, risk acceptance, audits, compensating controls, and treatment planning.

THINK LIKE A MANAGER Show decision-makers both the reduction achieved and what remains; do not present a control as eliminating risk.

EXAM TRAPS

- Reporting inherent risk as though controls do not exist.
- Calling residual risk zero without strong justification.
- Ignoring operational or concentration risk introduced by a new control or provider.
- Accepting residual risk at the wrong management level.

QUICK DISTINCTION Before controls = inherent. After controls = residual. Caused by the response = secondary.

Qualitative and Quantitative Risk Analysis

Easy definition: Qualitative analysis ranks risk using descriptive or ordinal scales; quantitative analysis estimates risk with numerical values, frequencies, and monetary impact.

When it matters: Prioritization, cost-benefit decisions, executive reporting, insurance, project comparison, and resource allocation.

THINK LIKE A MANAGER Use the method supported by reliable data and decision needs; document assumptions and avoid false precision.

EXAM TRAPS

- Assuming quantitative numbers are automatically objective.
- Comparing ordinal qualitative scores as if they were precise measurements.
- Spending excessive effort calculating uncertain values when a qualitative decision is sufficient.
- Ignoring intangible impacts because they are difficult to monetize.

QUICK DISTINCTION Qualitative = relative ranking. Quantitative = numeric estimate. Both depend on judgment and data quality.

SLE, ARO, and ALE

Easy definition: Single Loss Expectancy estimates loss from one event; Annualized Rate of Occurrence estimates events per year; Annualized Loss Expectancy estimates yearly loss exposure.

When it matters: Quantitative risk analysis and comparing the expected benefit of safeguards.

THINK LIKE A MANAGER Use the estimates to support—not mechanically dictate—a decision, and include nonfinancial, legal, safety, and strategic impacts.

EXAM TRAPS

- Using asset value instead of exposure factor when calculating SLE.
- Treating ARO as a guarantee that an event will occur on schedule.
- Ignoring control operating costs and residual ALE.
- Choosing a safeguard solely because its purchase price is below ALE.

QUICK DISTINCTION $SLE = \text{Asset Value} \times \text{Exposure Factor}$. $ALE = SLE \times ARO$. Approximate annual safeguard value = ALE before – ALE after – annual control cost.

Quantitative Example

Input	Value	Result
Asset value	\$1,000,000	—
Exposure factor	25%	$SLE = \$250,000$
ARO	0.2 (once per 5 years)	$ALE = \$50,000/\text{year}$
Control reduces ALE to \$10,000	Annual control cost = \$20,000	Estimated net annual benefit = \$20,000

Control Categories and Functions

Easy definition: Controls may be administrative/managerial, technical/logical, or physical; their functions may be preventive, deterrent, detective, corrective, recovery, or compensating.

When it matters: Defense in depth, control selection, audit findings, exceptions, and risk treatment.

THINK LIKE A MANAGER Select a balanced set that addresses people, process, technology, detection, response, and recovery; verify that controls actually reduce the target risk.

EXAM TRAPS

- Assuming one control has only one function.
- Confusing control category with control function.
- Choosing only preventive controls and ignoring detection and recovery.
- Using a compensating control that does not provide comparable risk reduction.
- Counting multiple controls that share one failure mode as true defense in depth.

QUICK DISTINCTION Category describes what the control is; function describes what it does.

Continuous Monitoring, Reporting, and Improvement

Easy definition: Risk management is a continuing cycle of monitoring controls and conditions, reporting meaningful indicators, reviewing decisions, and improving maturity.

When it matters: Changing threats, control drift, exceptions, third parties, new technology, audit findings, and executive oversight.

THINK LIKE A MANAGER Report trends, thresholds, business impact, ownership, and decisions needed—not a pile of unprioritized technical data.

EXAM TRAPS

- Treating an annual risk assessment as sufficient for a rapidly changing environment.
- Confusing KPIs with KRIs.
- Reporting only activity counts rather than effectiveness or risk reduction.
- Failing to reassess accepted risk and expiring exceptions.
- Using maturity scores as the goal instead of improved business outcomes.

QUICK DISTINCTION KPI measures performance of an activity or control; KRI signals increasing risk exposure; KGI indicates achievement of an outcome.

1.10 Threat Modeling

Threat Modeling Process

Easy definition: Threat modeling systematically identifies what is being built or protected, what can go wrong, what should be done, and whether mitigations are adequate.

When it matters: Architecture and design, new systems, major changes, trust boundaries, data flows, abuse cases, and control selection.

THINK LIKE A MANAGER Model threats early, include business and technical stakeholders, prioritize by risk, and track mitigations through verification.

EXAM TRAPS

- Waiting until production penetration testing to identify design threats.
- Starting with a threat list before defining scope, assets, data flows, and trust boundaries.
- Treating the model as a one-time document.
- Mitigating every theoretical threat equally.
- Ignoring misuse, privacy harm, human actors, and third-party dependencies.

QUICK DISTINCTION Threat modeling is proactive design analysis; vulnerability scanning discovers known weaknesses in implemented assets.

STRIDE, PASTA, and Attack Trees

Easy definition: STRIDE categorizes threats, PASTA is a risk-centric staged methodology, and attack trees decompose an attacker's goal into possible paths.

When it matters: Choosing a repeatable method appropriate to system complexity, risk, and organizational practice.

THINK LIKE A MANAGER Use the method to support consistent analysis and decisions; the model is a tool, not the objective.

EXAM TRAPS

- Memorizing acronyms without linking threats to security properties and mitigations.
- Assuming a single method is always best.
- Confusing an attack tree with a control hierarchy.
- Treating threat categories as proof that likelihood and impact were assessed.

QUICK DISTINCTION STRIDE: spoofing, tampering, repudiation, information disclosure, denial of service, elevation of privilege.

STRIDE Mapping

Threat	Primary property threatened	Illustrative control direction
Spoofing	Authenticity	Strong authentication and identity proofing
Tampering	Integrity	Validation, access control, hashes/signatures

Threat	Primary property threatened	Illustrative control direction
Repudiation	Nonrepudiation	Trusted logging, signatures, timestamps
Information disclosure	Confidentiality	Access control, encryption, minimization
Denial of service	Availability	Resilience, capacity, filtering, recovery
Elevation of privilege	Authorization	Least privilege, isolation, patching

1.11 Supply Chain Risk Management

Third-Party and Supply Chain Risk

Easy definition: Supply chain risk arises when suppliers, products, services, components, software, or dependencies can compromise confidentiality, integrity, availability, authenticity, safety, or compliance.

When it matters: Procurement, cloud, managed services, software components, hardware, updates, logistics, outsourcing, and concentration risk.

THINK LIKE A MANAGER Define minimum requirements before selection, perform risk-based due diligence, contract for obligations and evidence, monitor throughout service, and plan secure exit.

EXAM TRAPS

- Performing due diligence only after contract signature.
- Assuming certifications eliminate the need for scoping and evidence review.
- Assessing the direct vendor but ignoring subcontractors, dependencies, and concentration.
- Believing a contract transfers accountability.
- Failing to plan for termination, portability, data return, and destruction.

QUICK DISTINCTION Third-party risk is not only cyber risk; it includes resilience, privacy, legal, geopolitical, financial, operational, and concentration risk.

SBOM, Provenance, and Hardware Trust

Easy definition: An SBOM inventories software components and dependencies; provenance provides evidence of origin and integrity; hardware trust mechanisms help verify authentic and untampered components.

When it matters: Software vulnerabilities, counterfeit products, malicious implants, update integrity, component tracking, and incident response.

THINK LIKE A MANAGER Require transparency appropriate to risk, validate integrity and origin, monitor newly disclosed weaknesses, and maintain a response process.

EXAM TRAPS

- Treating an SBOM as a vulnerability scanner or proof that software is secure.
- Collecting an SBOM without monitoring components for new risk.
- Assuming a digital signature proves the signer is trustworthy or the content is safe.
- Focusing only on software and ignoring hardware, firmware, manufacturing, and logistics.

QUICK DISTINCTION SBOM tells what components exist; signatures and provenance help establish origin and integrity; neither alone proves acceptable risk.

Third-Party Lifecycle

Stage	Manager action	Common trap
Plan	Define business need, data, access, criticality, and requirements.	Beginning with a preferred vendor.
Select	Perform proportional due diligence and compare residual risk.	Accepting marketing claims or certificates without scope.

Stage	Manager action	Common trap
Contract	Set security, privacy, SLA, notification, audit, and exit terms.	Assuming an NDA is sufficient.
Operate	Monitor performance, changes, incidents, dependencies, and evidence.	Treating onboarding assessment as permanent assurance.
Exit	Revoke access; return/destroy data; preserve records; ensure continuity.	Ending payment but leaving access or data behind.

1.12 Security Awareness, Education, and Training

Awareness vs. Training vs. Education

Easy definition: Awareness builds recognition and attention, training teaches role-specific skills, and education develops broader understanding and professional capability.

When it matters: Program design, onboarding, recurring learning, privileged roles, developers, executives, and security professionals.

THINK LIKE A MANAGER Match content to audience and risk, reinforce it over time, and measure behavior and outcomes—not attendance alone.

EXAM TRAPS

- Giving every audience identical content.
- Calling an annual slide deck a complete program.
- Measuring success only by completion rate.
- Using punitive phishing simulations that discourage reporting.
- Failing to update material for new threats, technologies, policies, and business changes.

QUICK DISTINCTION Awareness = know and notice. Training = perform a task. Education = understand broadly and develop expertise.

Program Effectiveness and Behavior Change

Easy definition: An effective program reduces risky behavior and improves correct reporting, decision-making, and control performance using measurable objectives and continuous improvement.

When it matters: Phishing, social engineering, data handling, incident reporting, secure development, privileged administration, and emerging technologies such as AI.

THINK LIKE A MANAGER Define desired behaviors, establish a baseline, use relevant interventions, measure outcomes, and adjust based on evidence.

EXAM TRAPS

- Equating more training hours with lower risk.
- Using click rate as the only phishing metric.
- Ignoring positive indicators such as rapid reporting and correct escalation.
- Failing to distinguish knowledge gaps from poor process or unusable controls.
- Publishing metrics without context, trend, or action thresholds.

QUICK DISTINCTION Completion is a KPI; reporting speed, repeat susceptibility, policy violations, and incident trends better indicate risk and behavior change.

Cross-Domain Exam Traps for Domain 1

Who Decides?

Decision	Likely accountable role	Security professional's role
Set risk appetite	Board/executive leadership	Provide risk information and implications
Accept business risk	Authorized risk/business owner	Analyze, recommend, document, monitor
Classify information	Data/information owner	Provide criteria and control guidance
Interpret legal requirement	Qualified legal counsel	Explain technical facts and implement approved requirements
Implement/operate control	Custodian/operations role	Design, advise, verify, or oversee as assigned
Provide independent assurance	Auditor/assessment function	Evaluate evidence without owning the control

What Happens First?

- Immediate danger: protect life and safety, then stabilize the situation.
- New program or architecture: understand business objectives, scope, stakeholders, obligations, and risk before selecting controls.
- Business continuity: conduct the BIA before selecting recovery solutions.
- Intrusive test or investigation: obtain proper authorization and define scope before acting.
- Potential evidence: preserve integrity and document handling before analysis when circumstances permit.
- Third party: define requirements and perform due diligence before commitment and access.
- Risk acceptance: quantify or qualify risk, evaluate treatments, identify residual risk, and obtain owner approval.
- Policy failure: determine whether policy, standards, procedures, training, enforcement, or monitoring caused the gap before buying technology.

Words That Change the Answer

Question wording	What to look for
FIRST / INITIAL	Prerequisite: safety, authorization, scope, assessment, ownership, classification, or preservation.
BEST / MOST effective	Option that most directly reduces the stated business risk and fits constraints.
MOST important	People/safety, business mission, legal duty, or foundational governance objective.
MANAGEMENT should	Governance, risk decision, resources, accountability, policy, and oversight.
SECURITY professional should	Advise, assess, document, escalate, implement within authority—not assume business ownership.
PRIMARY purpose	The core objective, not a useful secondary benefit.

Domain 1 Rapid Review

ONE-SENTENCE DOMAIN SUMMARY Govern security so it supports the business: act ethically, understand obligations and impacts, assign accountable owners, treat risk proportionately, preserve continuity, manage people and suppliers, and verify that the program works.

High-Yield Distinctions

Concept A	Concept B	Fast distinction
Governance	Management	Direction and accountability vs. planning and execution
Due care	Due diligence	Take reasonable action vs. investigate and continually verify
Compliance	Security	Meet obligations vs. manage risk to objectives
Privacy	Confidentiality	Appropriate lifecycle and rights vs. prevention of unauthorized disclosure
BC	DR	Continue business functions vs. restore technology
BIA	Risk assessment	Impact of loss over time vs. threats, likelihood, and risk
RPO	RTO	Acceptable data-loss window vs. restoration time target
Risk owner	Control owner/custodian	Accepts consequence vs. implements or operates treatment
Inherent risk	Residual risk	Before controls vs. after controls
Threat modeling	Vulnerability scanning	Proactive design analysis vs. implemented weakness discovery
Awareness	Training	Recognize and care vs. perform a task correctly

Final Manager-Mindset Checklist

- What business objective, asset, person, or obligation is at risk?
- Is there an immediate safety issue?
- Who has authority and who owns the consequence?
- What must be known or approved before action?
- Does law, regulation, contract, ethics, or policy constrain the choice?
- Is the answer risk-based, proportionate, and aligned to business needs?
- Does it address the root cause and full lifecycle—not only the symptom?
- What residual risk remains, who accepts it, and how will it be monitored?
- Can the decision and control effectiveness be demonstrated with evidence?

Source and Scope Note

Coverage is aligned to the ISC2 CISSP Certification Exam Outline effective April 15, 2024. This guide is an independent study aid and is not official ISC2 courseware. It summarizes concepts in original language and does not reproduce exam questions.

Official outline: <https://www.isc2.org/certifications/cissp/cissp-certification-exam-outline>